

SOC

Incident Response

Modul SOC.F2601



Intro



<https://www.youtube.com/watch?v=2AjcnqbWOyY>

Programm

- Weshalb braucht man so was? (Hintergrund)
- Was versteht man eigentlich darunter?
- Wer ist involviert
- Begriffe, Organisationen, Standards, Frameworks, ...
- Incident Response Prozess
- Einordnen und Scoring
- Incident Response unterstützende Tools
- Incident Response Team
- Incident Response Playbooks
- Incident Response best practice





Hintergrund Incident Response

- Da Cyber-Angriffe immer mehr an Umfang, Vielfalt und Komplexität zunehmen und nicht nur störender und schädlicher sind, müssen sich Unternehmen darauf vorbereiten, effektiv mit ihnen umzugehen.
- Man muss nicht nur effektive Sicherheitslösungen und -praktiken bereitstellen, sondern die Angriffe auch schnell identifizieren und adressieren können, nur so kann man minimale Schäden, Störungen und Kosten sicherstellen.
- Jedes IT-System ist ein potenzielles Ziel eines Cyber-Angriffs, und die meisten Menschen sind sich einig, dass es nicht darum geht, ob, sondern wann es passieren wird. Die Auswirkungen hängen jedoch davon ab, wie schnell und effektiv man das Problem behebt. Daher ist eine Vorbereitung auf die Reaktion auf Vorfälle erforderlich.
- Eine Cybersecurity Incident Response (IR) bezieht sich auf eine Reihe von Prozessen, die ein Unternehmen unternimmt, um einen Angriff auf seine IT-Systeme zu bekämpfen. Dies erfordert eine Kombination der richtigen Hardware- und Softwaretools sowie Vorgehensweisen wie ordnungsgemäße Planung, Verfahren, Schulung und Unterstützung durch alle Mitarbeiter des Unternehmens.

Was versteht man unter Incident Response?

Incident Response ist ein koordinierter und strukturierter Ansatz, von der Erkennung eines Vorfalls bis zu dessen Lösung.

Die Reaktion auf einen Vorfall kann Aktivitäten umfassen, die:

- Bestätigen, ob ein Vorfall aufgetreten ist oder nicht
- Erkennung und Eingrenzung (möglichst schnell)
- Bestimmen und Dokumentieren des Umfangs des Vorfalls
- Verhinderung einer unzusammenhängenden, nicht kohärenten Reaktion
- Ermitteln von Fakten und aktuellen Informationen
- Minimieren der Unterbrechung des Geschäfts- und Netzwerkbetriebs
- Minimierung des Schadens für die betroffene Organisation
- Wiederherstellung des normalen Betriebs
- Verwaltung der öffentlichen Wahrnehmung des Vorfalls
- Strafrechtliche oder zivilrechtliche Schritte gegen die Täter einleiten
- Aufklärung der Geschäftsleitung
- Verbesserung der Sicherheitsvorkehrungen einer kompromittierten Organisation gegen zukünftige Vorfälle (lessons learned)



Wer ist involviert?

Die an der Bearbeitung eines Sicherheitsvorfalls typisch beteiligten Akteure sind:

- Informationssicherheit
- IT-Unterstützung
- Management
- Physische Sicherheit und Facility Management
- Business Continuity Planer
- Öffentlichkeitsarbeit und Medienarbeit
- Rechtsabteilung
- Personalwesen

- ...



Begriffe

- **IR** – Incident Response
- **CSIRT** – Computer Security Incident Response Team
- **Event** – Ereignis welches z.B. versucht den Sicherheitszustand eines Systems zu ändern
- **Incident** - Ein Vorfall welcher tatsächlich oder potenziell die Vertraulichkeit, Integrität oder Verfügbarkeit eines Informationssystems gefährdet
- **Observable** - Ereignis (gutartig oder böartig) in einem Netzwerk oder System
- **OSINT** – (Open Source Intelligence) Als OSINT wird der Vorgang bezeichnet, bei welchem über öffentlich zugängliche Informationsquellen Daten gesammelt, systematisch organisiert und ausgewertet werden.
- **IoC** (Indicators of Compromise) - Beobachtung welche darauf hinweist, dass ein Angriff unmittelbar bevorsteht oder im Gange ist.
- **Impersonation** – Vorgeben jemand zu sein (z.B. der Chef)



Indicators of Compromise (IoC)

Ein technisches Artefakt oder eine Beobachtung welche darauf hinweist, dass ein Angriff unmittelbar bevorsteht oder im Gange ist, oder dass eine Kompromittierung bereits stattgefunden haben könnte.

Arten von Indikatoren

- Prüfsummen von Malware Dateien (Hashvalue: MD5,SHA256)
- Domain Name/ URL von (möglich) C2 Servern
- IP-Adressen der C2 Server

Beschreiben von IoC

- Prosa Text
- Open IoC
- STIX
- YARA
- SNORT Rules
- Sigma



STIX

Structured Threat Information Expression (STIX) ist ein standardisiertes, maschinenlesbares Format, um Cyber-Threat Informationen strukturiert auszutauschen. Es beschreibt Angreifer, Kampagnen, Malware, IoCs und Zusammenhänge in einem gemeinsamen Datenmodell.

Es wird genutzt, um Bedrohungsdaten in einem einheitlichen **JSON-basierten Format** auszudrücken. Dadurch können verschiedene Sicherheitssysteme dieselben Informationen verstehen und automatisiert verarbeiten.

Damit ermöglicht STIX eine konsistente, standardisierte Beschreibung von Bedrohungen, sodass Organisationen Informationen leichter austauschen und automatisiert verarbeiten können.

→ Es funktioniert wie eine gemeinsame Sprache zwischen Sicherheitstools.

Aufbau von STIX

- STIX besteht aus Objekten, die verschiedene Aspekte einer Bedrohung beschreiben. Die offizielle Spezifikation listet u. a. folgende Objekttypen:
 - **Attack Pattern** – beschreibt Angriffsverfahren
 - **Campaign** – zusammenhängende Angriffsserien
 - **Indicator** – Muster zur Erkennung von Bedrohungen
 - **Malware** – Beschreibung einer Malware-Familie
 - **Identity** – Akteure oder Organisationen
 - **Course of Action** – empfohlene Gegenmassnahmen
- Diese Objekte werden über Beziehungen miteinander verknüpft, um komplexe Bedrohungsbilder abzubilden.

Beispiel STIX

Indikator für bösartige URLs

Eine sehr verbreitete Methode, um Malware an potenzielle Opfer zu verbreiten, besteht darin, sie unter einer bestimmten URL zu hosten.

Die Opfer werden dann über eine Phishing-E-Mail oder einen Link von einer anderen Website auf diese URL weitergeleitet und dort angegriffen.

→ Das Teilen von Listen mit bösartigen URLs kann eine wirksame und kostengünstige Möglichkeit sein, das Risiko einer Infektion mit bösartiger Software zu verringern.

STIX Beispiele: <https://oasis-open.github.io/cti-documentation/stix/examples>

```

1  {
2    "type": "bundle",
3    "id": "bundle--56be2a3b-1534-4bef-8fe9-602926274089",
4    "objects": [
5      {
6        "type": "indicator",
7        "spec_version": "2.1",
8        "id": "indicator--d81f86b9-975b-4c0b-875e-810c5ad45a4f",
9        "created": "2014-06-29T13:49:37.079Z",
10       "modified": "2014-06-29T13:49:37.079Z",
11       "name": "Malicious site hosting downloader",
12       "description": "This organized threat actor group operates to create profit from all types of crime.",
13       "indicator_types": [
14         "malicious-activity"
15       ],
16       "pattern": "[url:value = 'http://x4z9arb.cn/4712/']",
17       "pattern_type": "stix",
18       "valid_from": "2014-06-29T13:49:37.079Z"
19     },
20     {
21       "type": "malware",
22       "spec_version": "2.1",
23       "id": "malware--162d917e-766f-4611-b5d6-652791454fca",
24       "created": "2014-06-30T09:15:17.182Z",
25       "modified": "2014-06-30T09:15:17.182Z",
26       "name": "x4z9arb backdoor",
27       "description": "This malware attempts to download remote files after establishing a foothold as a backdoor.",
28       "malware_types": [
29         "backdoor",
30         "remote-access-trojan"
31       ],
32       "is_family": false,
33       "kill_chain_phases": [
34         {
35           "kill_chain_name": "mandiant-attack-lifecycle-model",
36           "phase_name": "establish-foothold"
37         }
38       ]
39     },
40     {
41       "type": "relationship",
42       "spec_version": "2.1",
43       "id": "relationship--864af2ea-46f9-4d23-b3a2-1c2adf81c265",
44       "created": "2020-02-29T18:03:58.029Z",
45       "modified": "2020-02-29T18:03:58.029Z",
46       "relationship_type": "indicates",
47       "source_ref": "indicator--d81f86b9-975b-4c0b-875e-810c5ad45a4f",
48       "target_ref": "malware--162d917e-766f-4611-b5d6-652791454fca"
49     }
50   ]
51 }

```



Unterschied Incident und Event

Event (Ereignis)

- Ein Event ist jedes beobachtbare Vorkommnis in Ihrer IT-Infrastruktur. Ein Ereignis kann etwas so harmloses und unauffälliges sein wie das Tippen auf einer Tastatur oder der Empfang einer E-Mail. Ein Ereignis muss nicht zwangsläufig ein Problem sein; die Aktualisierung Ihrer Firewall ist ein Ereignis.
- Sicherheitsereignisse sind Ereignisse, die sich speziell auf Ihre Informationssicherheit auswirken können.

Incident (Vorfall)

- Nicht alle Events sind Incidents, aber alle Incidents sind Events. Ein Incident ist ein Ereignis, das IT-Systeme negativ beeinflusst und Auswirkungen auf das Geschäft hat. Es ist eine ungeplante Unterbrechung oder Qualitätsminderung eines IT-Services. Zum Beispiel sind ein DDoS-Angriff oder die Überflutung eines Serverraums beides Vorfälle.

Events müssen nicht negativ sein – Incidents sind es immer.

Während die meisten Sicherheitsereignisse nicht behandelt werden müssen, erfordert ein Sicherheitsvorfall Massnahmen.

Organisationen, Standards & Frameworks

- NIST (<https://www.nist.gov/>)
- ENISA (<https://www.enisa.europa.eu/>)
- SANS (<https://www.sans.org/>)
- First (<https://www.first.org/>)
- ...



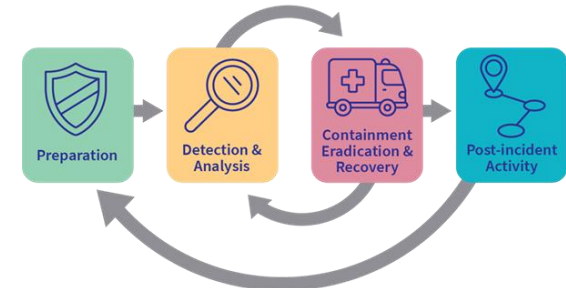
Publikationen & Links

- <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r3.pdf>
- <https://www.enisa.europa.eu/publications/strategies-for-incident-response-and-cyber-crisis-cooperation>
- <https://www.sans.org/reading-room/whitepapers/incident/incident-handlers-handbook-33901>
- <https://www.first.org/global/sigs/csirt/>

Incident Response (nach NIST)

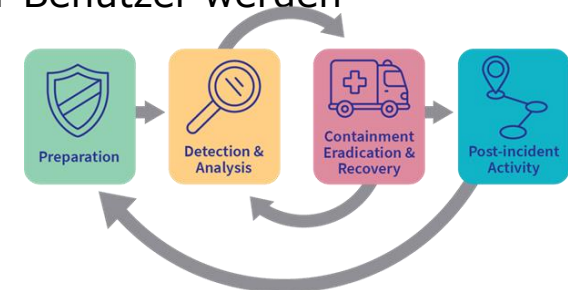
NIST definiert vier Schritte im Lebenszyklus des Incident-Response-Prozesses:

- **Preparation** (Vorbereitung) - Die Mitglieder des CSIRT werden darin geschult, wie sie auf einen Vorfall reagieren sollen.
- **Detection & Analysis** (Erkennung und Analyse) - Das CSIRT identifiziert, analysiert und validiert einen Vorfall schnell.
- **Containment & Eradiction & Recovery** (Eindämmung, Beseitigung und Wiederherstellung) - Das CSIRT implementiert Verfahren zur Eindämmung der Bedrohung, zur Beseitigung der Auswirkungen auf die Unternehmensressourcen und zur Wiederherstellung von Daten und Software mithilfe von Backups.
- **Post-Incident Activity** (Aktivitäten nach dem Vorfall) - Das CSIRT dokumentiert, wie der Vorfall gehandhabt wurde, empfiehlt Änderungen für zukünftige Reaktionen und legt fest, wie ein erneuter Vorfall vermieden werden kann.



Preparation

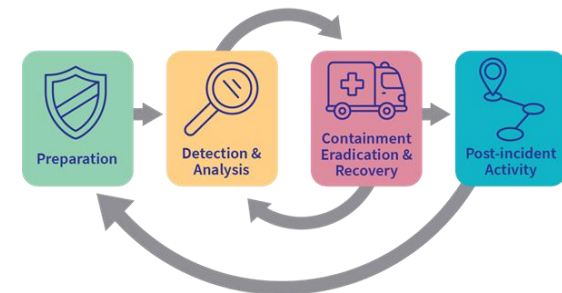
- Die Vorbereitungsphase ist die Zeit, in der das CSIRT gegründet und geschult wird. Die Werkzeuge und Mittel welche das Team zur Untersuchung von Vorfällen benötigt, werden erworben und eingesetzt.
- Die Beispiele für Aktionen in der Vorbereitungsphase sind wie folgt:
 - Einrichtungen zur Unterbringung des Reaktionsteams und des SOC werden geschaffen.
 - Risikobewertungen werden verwendet, um Kontrollen zu implementieren welche die Anzahl der Vorfälle begrenzen.
 - Schulungsmaterialien für das Sicherheitsbewusstsein der Benutzer werden entwickelt.
 - Notwendige Hard- und Software für die Analyse von Vorfällen und die Schadensbegrenzung wird angeschafft.



Detection & Analysis

Verschiedene Arten von Vorfällen erfordern unterschiedliche Reaktionen.

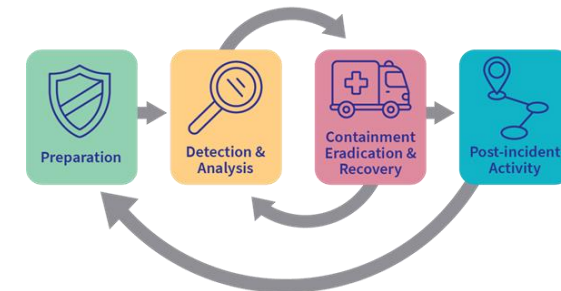
- **Angriffsvektoren:** Web, E-Mail, Verlust oder Diebstahl, Impersonation, ...
- **Erkennung:** Automatisierte Erkennung - Antiviren-Software, IDS, manuelle Erkennung - Benutzerberichte.
- **Analyse:** Verwendung von Netzwerk- und System-Profiling, um die Gültigkeit von Sicherheitsvorfällen zu bestimmen.
- **Scoping:** Bereitstellung von Informationen zur Eingrenzung des Vorfalls und tiefergehende Analyse der Auswirkungen des Vorfalls.
- **Incident-Benachrichtigung:** Benachrichtigung der entsprechenden Stakeholder und externen Parteien, sobald der Vorfall analysiert und priorisiert wurde



Containment, Eradication* and Recovery

Nachdem die Gültigkeit des Vorfalls durch Erkennung und Analyse festgestellt wurde, muss er eingedämmt werden.

- **Eindämmungsstrategie:** Für jede Art von Vorfall sollte eine Eindämmungsstrategie erstellt und in Abhängigkeit von einigen Bedingungen durchgesetzt werden.
- **Beweise:** Während eines Vorfalls müssen Beweise gesammelt werden, um ihn aufzuklären. Diese werden für die anschließende Untersuchung durch die Behörden benötigt.
- **Identifizierung des Angreifers:** Durch die Identifizierung der Angreifer werden die Auswirkungen auf kritische Unternehmensressourcen und -dienste minimiert.
- **Ausrottung, Wiederherstellung und Sanierung:**
Zur Ausrottung identifiziert man alle zu bereinigende Hosts; zur Wiederherstellung von Hosts verwendet man saubere und aktuelle Backups oder stellt sie mit Installationsmedien wieder neu her.



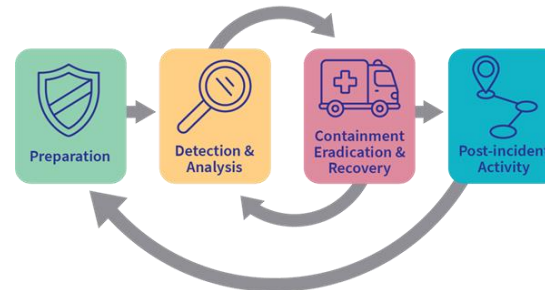
* Ausmerzung, Tilgung, Beseitigung

Post-Incident Activities

Es ist wichtig, sich in regelmässigen Abständen mit allen Beteiligten zu treffen, um die Ereignisse welche stattgefunden haben, und die Handlungen aller Personen bei der Handhabung des Vorfalls zu besprechen.

Die Organisation sollte ein "Lessons Learned"-Treffen abhalten, um:

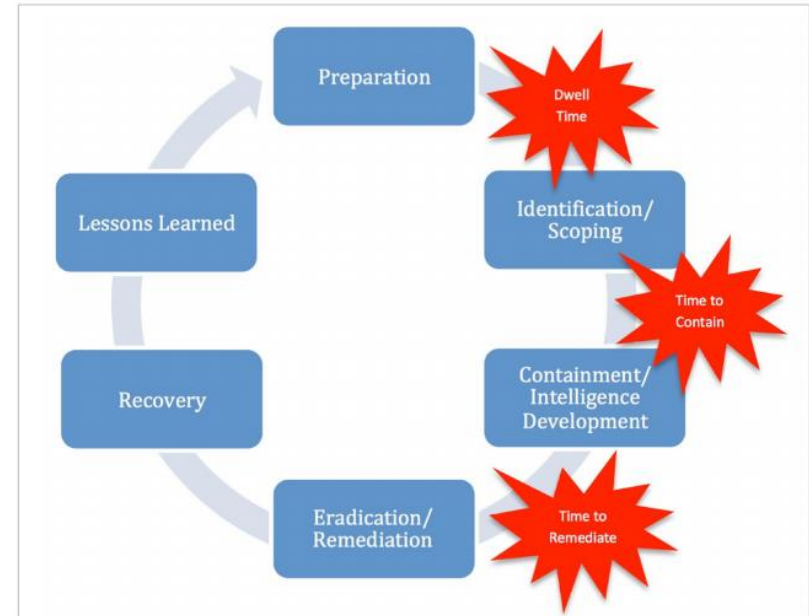
- Überprüfung der Effektivität des Prozesses zur Behandlung des Vorfalls.
- Identifizierung der notwendigen Härtung für bestehende Sicherheitskontrollen und -praktiken.



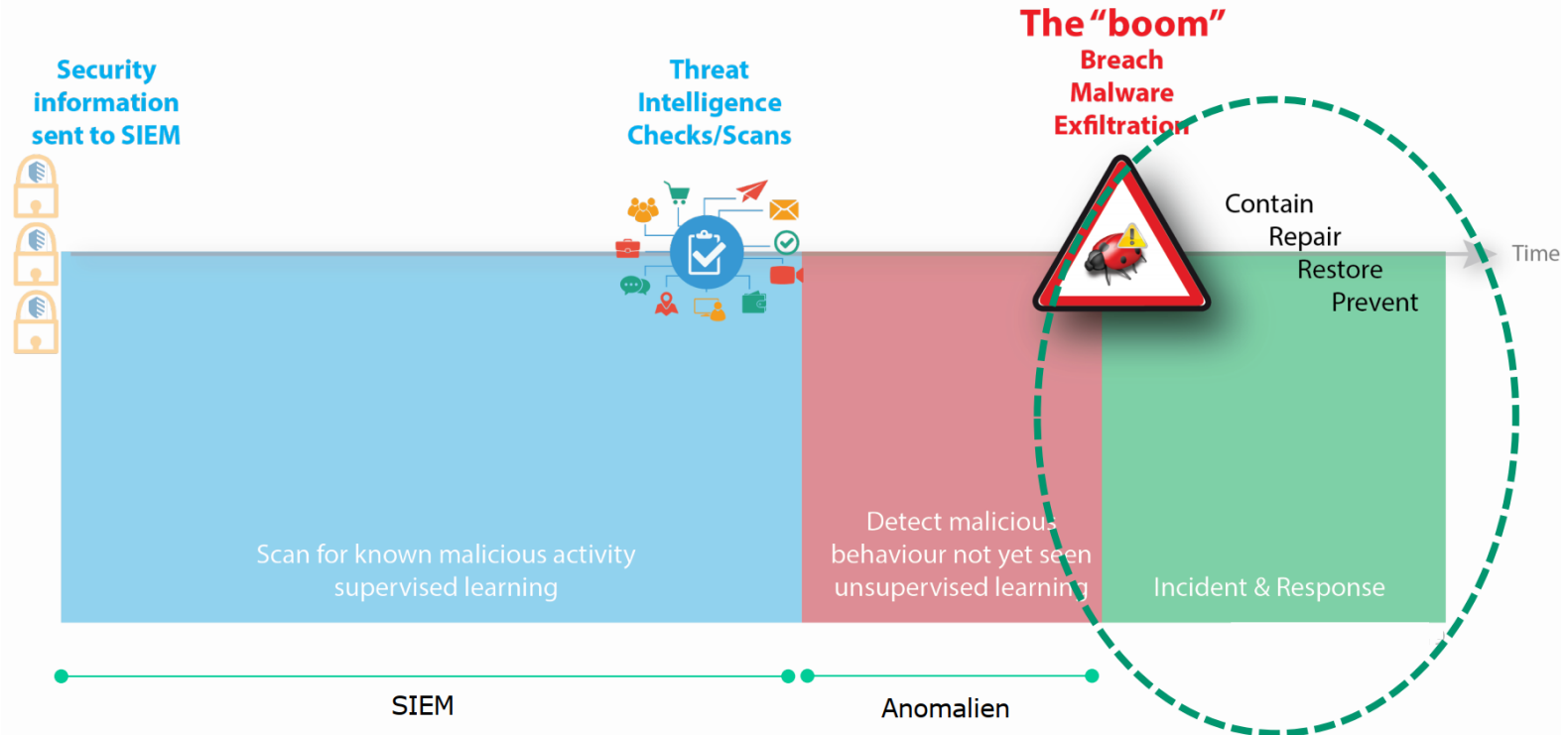
Incident Response nach SANS

Im Gegensatz zu NIST leicht
erweitert/verfeinert um:

- **Identification/Scoping:** Umfang und Auswirkung in Detail zu verstehen
- **Containment/Intelligence/Development:** Wie können wir die Situation am besten eingrenzen ohne dass ein Angreifer merkt, dass er entdeckt wurde.

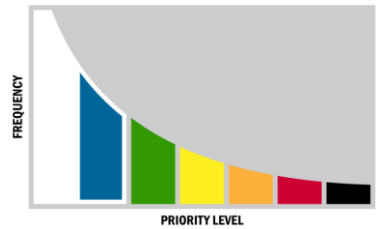


IR auf der Zeitachse



Einordnen des Incidents (Kategorie)

Kategorie	Beschreibung	Charakteristik
Insider	Vorsätzliche unerlaubte Handlungen eines Mitarbeiters um z.B. Zugang zu sensiblen Daten zu erhalten	Beizug von Rechtsabteilung und HR Vertrauliche Bearbeitung Ev. Miteinbezug von Ermittlungsbehörden
Targeted Attack	Spearphishing, Watering Hole, diverse Systeme mit komplexer Malware vorhanden, Kommunikation zu Angreifer-Infrastruktur über versteckte Kommunikationskanäle	Keine Offenlegung gegenüber dem Angreifer, Out-Of-Band Kommunikation Kann langwieriger IR-Prozess sein Ev. Miteinbezug externer/staatlicher Stellen/Behörden
Business / Compliance relevant	Kundendatenleck in einer Business-Applikation, Malware auf einzelnen Business-Servern	Abgestimmtes und vorsichtiges Vorgehen bei Compliance, Miteinbezug betroffene Abteilung bei IR, ggf. Miteinbezug Medien
Malware	Malware/Angriff breitet sich sehr rasch/ohne Benutzerinteraktion, selbsttätig aus und hat das Potential grossen Schaden anzurichten	Sehr rasche Reaktion erforderlich Ggf. einschneidende Containment-Massnahmen einleiten
Das "Übliche" (comodity)	z.B. einfaches Phishing oder "Malware-Mail" auf einzelnen PCs, etc.	Keine besonderen Massnahmen erforderlich



Einordnen des Incidents (Priorität)

Sind staatliche oder zur kritischen Infrastruktur zählende Stellen betroffen werden häufig Priorisierung und Einschätzung des Incidents anhand folgender Schemas gemacht:

- **NOTFALL (SCHWARZ)** Ein Vorfall mit Notfallpriorität stellt eine unmittelbare Bedrohung für die Bereitstellung von weitreichenden kritischen Infrastrukturdienste, die Stabilität der nationalen Regierung oder das Leben von Bürgern.
- **SCHWER (ROT)** Ein Vorfall der Priorität "Schwer" wird wahrscheinlich zu einer erheblichen Beeinträchtigung der öffentlichen Gesundheit oder Sicherheit führen, die nationale Sicherheit, die wirtschaftliche Sicherheit, die Aussenbeziehungen oder die bürgerlichen Freiheiten.
- **HOCH (ORANGE)** Ein Vorfall mit hoher Priorität wird wahrscheinlich zu einer nachweisbaren Auswirkung auf die öffentliche Gesundheit oder Sicherheit führen, die nationale Sicherheit, die wirtschaftliche Sicherheit, die Aussenbeziehungen, die bürgerlichen Freiheiten oder das öffentliche Vertrauen.
- **MITTEL (GELB)** Ein Vorfall mittlerer Priorität kann Auswirkungen auf die öffentliche Gesundheit oder Sicherheit, die nationale Sicherheit, die wirtschaftliche Sicherheit, Aussenbeziehungen, bürgerliche Freiheiten oder das Vertrauen der Öffentlichkeit beeinträchtigen.
- **NIEDRIG (GRÜN)** Es ist unwahrscheinlich, dass ein Vorfall mit niedriger Priorität die öffentliche Gesundheit oder Sicherheit, die nationale Sicherheit, die wirtschaftliche Sicherheit, die Aussenbeziehungen, die bürgerlichen Freiheiten oder das Vertrauen der Öffentlichkeit beeinträchtigen.

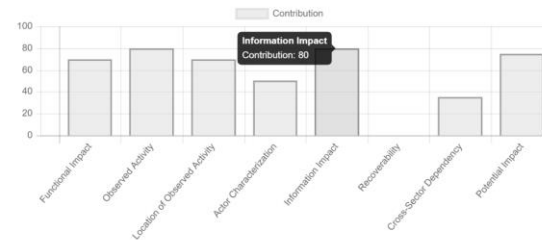
Incident Score

- Ist man sich nicht über die Schwere des Incidents sicher kann man sich helfen lassen.
- Unter <https://us-cert.cisa.gov/nciss/demo> stand ein interaktives Hilfsmittel zur Ermittlung der Schwere (Score) zur Verfügung (aktuell zu finden unter: <https://web.archive.org/web/20210124032051/us-cert.cisa.gov/nciss/demo>)



Select Options to Update Score

Make selections for each scoring option and the score will update automatically. Please note that the default options are counted as 0 and the score will not be accurate until selections are made for all options. Click on category names (e.g. Functional Impact, Observed Activity, etc.) to view help text. To reconfigure the options, see the next section below.



Calculated Score: Medium (55) [Clear all selections](#) *Currently loaded configuration*

Functional Impact

- ☐ No Impact
- ☐ No Impact to Services
- ☐ Minimal Impact to Non-Critical Services
- ☐ Minimal Impact to Critical Services
- ☐ Significant Impact to Non-Critical Services
- ☐ Denial of Non-Critical Services
- ☒ Significant Impact to Critical Services
- ☐ Denial of Critical Services or Loss of Control

6

0

20

35

40

50

60

70

100

Calculated Score

55



Selection Contributions

Functional Impact 70
Observed Activity 80
Location of Observed Activity 70
Actor Characterization 50
Information Impact 80
Recoverability 0
Cross-Sector Dependency 35
Potential Impact 75



IR Score Übung:

Berechnen Sie den Score folgender Fälle:
(copy-paste der abgegebenen Konfiguration ins Formular unten)

Übungsfälle:

- Rootkit auf dem AD-Server
- Firmenwebshop wurde "de-faced"
- Phishingmail wurde von normalem Benutzer angeklickt und User/PW eingegeben
- Mail mit Malware wurde geöffnet und aktiviert
- mit Malware verseuchter PC wurde am Firmennetzwerk angeschlossen (BYOD)
- Ransomware auf PC eines Atomkraftwerk-Mitarbeiters
- Vulnerability auf dem Remote-Access-Gateways einer Unternehmung
- grosser/riesiger Datenabfluss auf dem Proxy festgestellt

Grundsätzliche Herausforderungen bei IR

- Cyberattacken werden intensiver und raffinierter und somit schwieriger zu entdecken
- Verschiedene, teils isolierte Tools und Systeme in der IT-Organisation (Medienbrüche)
- Anzahl Events und Aktivitäten in der IT-Umgebung steigen fast exponentiell mit dem Business Erfolg (organisches Wachstum)
- Mangelnde Kenntnis über die eigenen IT-Infrastruktur aufgrund fehlender Information und Dokumentation in der Organisation
- Eventuell bestehende Lücken zwischen Informatik/SW Entwicklung, Security Engineering und Incident Response Teams
- Mangel an erfahrenen Spezialisten im Unternehmen und auf dem Arbeitsmarkt
- Unklare und vage Richtlinien der Unternehmung bzw. der Behörden

Wie passt MITRE ATT&CK Framework und IR zusammen?

Enterprise Matrix

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion
Drive-by Compromise	AppleScript	.bash_profile and .bashrc	Access Token Manipulation	Access Token Manipulation
Exploit Public-Facing Application	MSFTP	Accessibility Features	Accessibility Features	Application Access Token
External Remote Services	Command-Line Interface	Account Manipulation	AppCert DLLs	Binary Padding
Malicious Additions	Compiled HTML File	AppCert DLLs	AppInit DLLs	BITS Jobs
Phishing Through Social Media	Component Object Model and Distributed COM	AppInit DLLs	Application Shimming	Bypass User Account Control
Software Component	Control Panel Items	Application Shimming	Bypass User Account Control	Clear Command History
Web Service	Dynamic Data Exchange	Authentication Package	Clear Command History	Clear Command History
Service	Execution through API	BITS Jobs	Clear Command History	Clear Command History
Supply Chain Compromise	Execution through Module Load	Bootkit	Clear Command History	Clear Command History
Trusted Relationship	Exploitation for Client Execution	Browser Extensions	Clear Command History	Clear Command History
Valid Accounts	Graphical User Interface	Change Default File Association	Clear Command History	Clear Command History

SIEM meldet verdächtige Aktivitäten

Der nächste Schritt in der Attacke?



PRE-ATT&CK

- Priority Definition
- Planning, Direction
- Target Selection
- Information Gathering
- Technical, People, Organizational
- Weakness Identification
- Technical, People, Organizational
- Adversary OpSec
- Establish & Maintain Infrastructure
- Persona Development
- Build Capabilities
- Test Capabilities
- Stage Capabilities

ATT&CK for Enterprise

- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Defense Evasion
- Credential Access
- Discovery
- Lateral Movement
- Collection
- Exfiltration
- Command and Control
- Impact

TLP – Traffic Light Protocol

- TLP ist eine standardisierte Vereinbarung zum Austausch von schutzwürdigen Informationen.
- Das TLP dient der Erhöhung der Sicherheit bei der Weitergabe sensibler Daten. Alle Dokumente werden in eine von vier Klassen eingeteilt, welche die Bedingungen für ihre Weitergabe regeln.

<https://www.cisa.gov/tlp>
<https://www.first.org/tlp/>

Color	When should it be used?	How may it be shared?
 TLP:RED Not for disclosure, restricted to participants only.	Sources may use TLP:RED when information cannot be effectively acted upon by additional parties, and could lead to impacts on a party's privacy, reputation, or operations if misused.	Recipients may not share TLP:RED information with any parties outside of the specific exchange, meeting, or conversation in which it was originally disclosed. In the context of a meeting, for example, TLP:RED information is limited to those present at the meeting. In most circumstances, TLP:RED should be exchanged verbally or in person.
 TLP:AMBER Limited disclosure, restricted to participants' organizations.	Sources may use TLP:AMBER when information requires support to be effectively acted upon, yet carries risks to privacy, reputation, or operations if shared outside of the organizations involved.	Recipients may only share TLP:AMBER information with members of their own organization, and with clients or customers who need to know the information to protect themselves or prevent further harm. Sources are at liberty to specify additional intended limits of the sharing; these must be adhered to.
 TLP:GREEN Limited disclosure, restricted to the community.	Sources may use TLP:GREEN when information is useful for the awareness of all participating organizations as well as with peers within the broader community or sector.	Recipients may share TLP:GREEN information with peers and partner organizations within their sector or community, but not via publicly accessible channels. Information in this category can be circulated widely within a particular community. TLP:GREEN information may not be released outside of the community.
 TLP:WHITE Disclosure is not limited.	Sources may use TLP:WHITE when information carries minimal or no foreseeable risk of misuse, in accordance with applicable rules and procedures for public release.	Subject to standard copyright rules, TLP:WHITE information may be distributed without restriction.



IR-Team

- IT-Teams + Backup (Minimum)
- CERT/SOC Leiter
- SOC-Analysten & Threat Intelligence Analysten
- Forensik (ev. von extern beiziehen)
- Malware Analysten
- IT-Teams und Management
- Management und CIO / CTO / CEO
- Customer Relations & Unternehmens-Kommunikation
- externe/interne Revision
- nach Bedarf externe Dienstleister (ggf. staatliche Stellen)

bei fatalem
Incident

Vorbereitung: Playbooks



Was man mit den Playbooks erreichen will:

- Standardisierung/Normierung des Ablaufs
→ Steigerung der Zuverlässigkeit, Vermeidung von Fehlern, etc.
- Mittel und Massnahmen sind vorbereitet
- Vorstufe zur Automation

Aufbau

- Passend zu den IR-Phasen
- mit Anweisungen und zu verwendenden Tools

Vorgehen

- Fokus auf die am häufigsten auftretende Fälle (z.B. Malware-Befall, Phishing, etc.)
- kein Roman, kurz und auf den Punkt gebracht, Step-by-Step, z.B. als Wiki
- kann laufend ergänzt werden

Beispiel Playbook

Workflow:

- Execute Response Actions step by step. Some of them directly connected, which means you will not be able to move forward not finishing the previous step. Some of them are redundant, as those that are related to the blocking a threat using network filtering systems (containment stage)
- Start executing containment and eradication stages concurrently with next identification steps, as soon as you will receive information about malicious hosts
- If phishing led to code execution or remote access to victim host, immediately start executing Generic Post Exploitation Incident Response Playbook
- Save all timestamps of implemented actions in Incident Report draft on the fly, it will save a lot of time

<https://atc-project.github.io/atc-react/>

RP0001: Phishing email

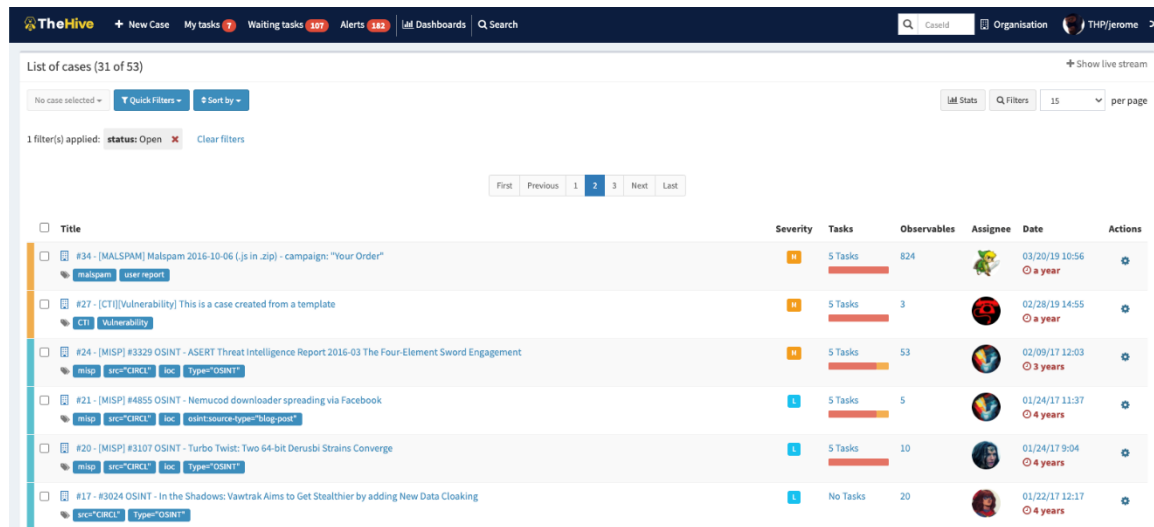
ID	RP0001
Description	Response playbook for Phishing Email case
Author	@atc_project
Creation Date	2019/01/31
Severity	M
TLP	AMBER
PAP	WHITE
ATT&CK Tactic	TA0001: Initial Access
ATT&CK Technique	• T1566.001: Spearphishing Attachment • T1566.002: Spearphishing Link
Tags	phishing
Preparation	• RA1001: Practice • RA1002: Take trainings • RA1004: Make personnel report suspicious activity • RA1003: Raise personnel awareness • RA1101: Access external network flow logs • RA1104: Access external HTTP logs • RA1106: Access external DNS logs • RA1111: Get ability to block external IP address • RA1113: Get ability to block external domain • RA1115: Get ability to block external URL • RA1201: Get ability to list users opened email message • RA1202: Get ability to list email message receivers • RA1203: Get ability to block email domain • RA1204: Get ability to block email sender • RA1205: Get ability to delete email message • RA1206: Get ability to quarantine email message
Identification	• RA2003: Put compromised accounts on monitoring • RA2113: List hosts communicated with external domain • RA2114: List hosts communicated with external IP • RA2115: List hosts communicated with external URL • RA2201: List users opened email message • RA2202: Collect email message • RA2203: List email message receivers • RA2204: Make sure email message is phishing • RA2205: Extract observables from email message
Containment	• RA3101: Block external IP address • RA3103: Block external domain • RA3105: Block external URL • RA3201: Block domain on email • RA3202: Block sender on email • RA3203: Quarantine email message
Eradication	• RA4001: Report incident to external companies • RA4201: Delete email message
Recovery	• RA5101: Unblock blocked IP • RA5102: Unblock blocked domain • RA5103: Unblock blocked URL • RA5201: Unblock domain on email • RA5202: Unblock sender on email • RA5203: Restore quarantined email message
Lessons learned	• RA6001: Develop incident report • RA6002: Conduct lessons learned exercise

IR unterstützende Tools und (Online-) Services

- Bestehende (Security-) Infrastruktur (SIEM, Logs, ...)
- Endpoint Detect and Response (EDR)
- Online Services:
 - Malware Information Sharing Platform (MISP)
 - Threat Intelligence Platform (TIP)
 - z.B. Virustotal
- Forensische Tools (z.B. SANS SIFT, The Sleuth Kit (+Autopsy), CAINE, ...)
- Malware Analyse Tool (z.B. Ghidra, x64dbg, ...)

The Hive Project

"The Hive is a scalable 3-in-1 open source and free **Security Incident Response Platform** designed to make life easier for SOCs, CSIRTs, CERTs and any information security practitioner dealing with security incidents that need to be investigated and acted upon swiftly."



The screenshot shows the TheHive web interface. At the top is a navigation bar with links for 'New Case', 'My tasks', 'Waiting tasks' (107), 'Alerts' (183), 'Dashboards', and 'Search'. Below this is a search bar and a 'Show live stream' button. The main content area is titled 'List of cases (31 of 53)'. It includes a filter section with 'Quick Filters' and 'Sort by'. A filter is applied: 'status: Open'. Below the filter is a table of cases. The table has columns: Title, Severity, Tasks, Observables, Assignee, Date, and Actions. The cases listed are:

Title	Severity	Tasks	Observables	Assignee	Date	Actions
#34 - [MALSPAM] Malspam 2016-10-06 (.js in .zip) - campaign: "Your Order"	5	5 Tasks	824	[Avatar]	03/20/19 10:56 4 years	[Icon]
#27 - [CTI][Vulnerability] This is a case created from a template	5	5 Tasks	3	[Avatar]	02/28/19 14:55 4 years	[Icon]
#24 - [MISP] #3329 OSINT - ASERT Threat Intelligence Report 2016-03 The Four-Element Sword Engagement	5	5 Tasks	53	[Avatar]	02/09/17 12:03 3 years	[Icon]
#21 - [MISP] #4855 OSINT - Nemucod downloader spreading via Facebook	5	5 Tasks	5	[Avatar]	01/24/17 11:37 4 years	[Icon]
#20 - [MISP] #3107 OSINT - Turbo Twist: Two 64-bit Derusbi Strains Converge	5	5 Tasks	10	[Avatar]	01/24/17 9:04 4 years	[Icon]
#17 - #3024 OSINT - In the Shadows: Vawtrak Aims to Get Stealthier by adding New Data Cloaking	5	No Tasks	20	[Avatar]	01/22/17 12:17 4 years	[Icon]



MISP

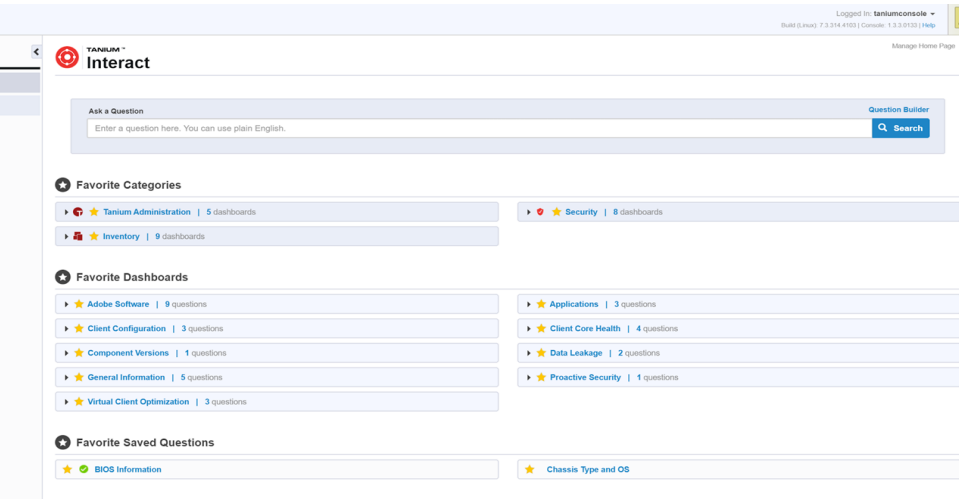
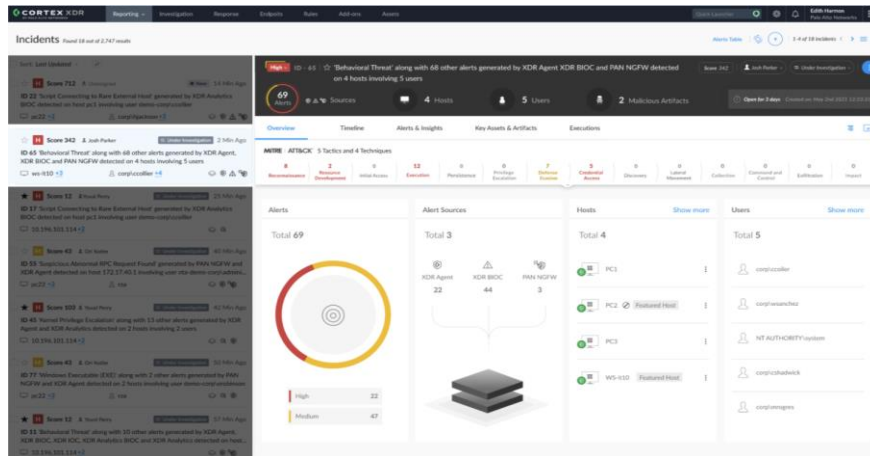
"MISP is a threat intelligence platform for sharing, storing and correlating **Indicators of Compromise** of targeted attacks, threat intelligence, financial fraud information, vulnerability information or even counter-terrorism information."

The screenshot shows the MISP web interface in a browser. The top navigation bar includes links for Home, Event Actions, Input Filters, Output Actions, Item Actions, Administration, Audit, and Discussions. The left sidebar contains a 'View Event' section with options like View Correlation Graph, View Event History, Edit Event, Delete Event, Add Attribute, Add Attachment, Populate from..., Merge attributes from..., Contact Reporter, and Download as... Below this is a 'List Events' section with 'Add Event'. The main content area displays the details of an event titled 'OSINT - Octopus-Rex. Evolution of a multi task Botnet'. The event details include: Event ID 5279, UUID 5813a113-42b-4279-1024-44a020a0d81, Org CIRCL, Owner org CIRCL, Contributors alexandre.dubourg@hsl.ch, Email ip-white, Tags 'c2-server', 'malware-platform', 'linux', 'qbot incident classification', 'malware', and 'c2bot feed', Date 2016-10-28, Threat Level Low, Analysis Completed, Distribution All communities, Info 'OSINT - Octopus-Rex. Evolution of a multi task Botnet', Published Yes, Sightings 0 (0). Below the details is a 'Related Event' box showing '2016-09-16 (4925)' with Org CIRCL, Date 2016-09-16, and Info OSINT - ELF-Rex. At the bottom, there is a table of sightings with columns for Date, Org, Category, Type, Value, Comment, Related Events, IDS, Distribution, Sightings, and Actions. The table shows three sightings, all from CIRCL, categorized as 'Artifacts dropped' and 'md5'. The first two sightings are from 2016-10-28, and the third is from 2016-10-28. The table is filtered by 'File' and 'Network'.

EDR

EDR Endpoint Detection & Response

- Interaktion mit dem Endpunkt möglich → Situation untersuchen
- Client kann vom Netzwerk isoliert werden
- Prozesse beenden, Client Restart



<https://www.tanium.com/>
<https://www.paloaltonetworks.com/cortex/cortex-xdr>

IR-Übungsfall - 1

Dem Helpdesk eines Unternehmens meldet ein Benutzer, dass nach dem Download und Starten der Datei folgende Meldung gekommen ist:



Die Unternehmung setzt mehrere verschiedene Anti-Malware Produkte sowohl auf Clients als auch Servern und dem Internet-Proxy ein.

Beurteilen und behandeln Sie diesen Incident

IR-Übungsfall - 2

Aufgrund eines Hinweises eines Benutzers wurde dessen Client gescannt und eine verdächtige Datei identifiziert. Der Test dieser Datei bei VirusTotal ergab folgendes Bild:

Beurteilen und behandeln Sie diesen Incident

<https://www.virustotal.com>



26 engines detected this file

SHA-2562f9559024182f56c649ab6d7a992384f48a64e9be0ee69c5bcd9412569def528

File nameMemu-Installer.exe

File size3.34 MB

Last analysis2019-01-14 22:12:39 UTC

26 / 69

Detection

Details

Community

Ad-Aware	 Gen:Variant.Ursu.365488	AhnLab-V3	 PUP/Win32.InstallCore.C2917167
ALYac	 Gen:Variant.Ursu.365488	Arcabit	 Trojan.Ursu.D59380
Avast	 FileRepMalware	AVG	 FileRepMalware
BitDefender	 Gen:Variant.Ursu.365488	CrowdStrike Falcon	 malicious_confidence_100% (D)
Cybereason	 malicious.71ab5d	Emsisoft	 Gen:Variant.Ursu.365488 (B)
Endgame	 malicious (high confidence)	eScan	 Gen:Variant.Ursu.365488
ESET-NOD32	 Win32/InstallCore.Gen.A potentially unwanted	Fortinet	 W32/InnoMod.A
GData	 Gen:Variant.Ursu.365488	K7AntiVirus	 Adware (005104571)
K7GW	 Adware (005104571)	Malwarebytes	 Adware.InstallCore
MAX	 malware (ai score=85)	Microsoft	 PUA:Win32/PuWaders.B!ml
NANO-Antivirus	 Virus.Win32.Gen.ccmw	Rising	 PUF:InstallCore!1.AB2C (CLASSIC)
SentinelOne	 static engine - malicious	Sophos AV	 InnoMod (PUA)
Sophos ML	 heuristic	Webroot	 Adware.Installcore
Acronis	 Clean	AegisLab	 Clean

IR-Übungsfall - 3

Der Chef eines reinen Online Händlers erhält untenstehende E-Mail in der gedroht wird, den Shop lahmzulegen wenn er nicht innerhalb von 48h an eine bestimmte Adresse 2 Bitcoin bezahlt

Beurteilen und behandeln
Sie diesen Incident

Subject: Ransom request: DDOS ATTACK!

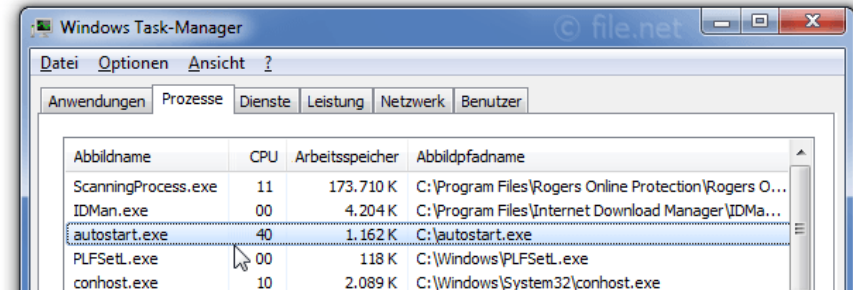
FORWARD THIS MAIL TO WHOEVER IS IMPORTANT IN YOUR COMPANY AND CAN MAKE DECISION! We are [Criminal Group].

All your servers will be DDoS-ed starting Friday if you don't pay 2 Bitcoins @ [BITCOIN ADDR] When we say all, we mean all – users will not be able to access sites host with you at all. Right now we will start 30 minutes attack on your site's IP (victims IP address). It will not be hard, we will not crash it at the moment to try to minimize eventual damage, which we want to avoid at this moment. It's just to prove that this is not a hoax. Check your logs! If you don't pay by Friday , attack will start, price to stop will increase to 4 BTC and will go up 20 BTC for every day of attack. This is not a joke."

IR-Übungsfall - 4

Zufällig wurde bei einer Untersuchung mehrerer Firmenserver (Windows) ein Programm entdeckt, das per Autostart bei jedem Neustart ausgeführt wird. Eine schnelle Untersuchung des Programms (VirusTotal, etc.) hat keinen Treffer ergeben und auch niemand vom Admin Personal kennt dieses Programm. Die Server stehen alle im gleichen Netzwerk Segment und haben eine AV/EDR Lösung installiert.

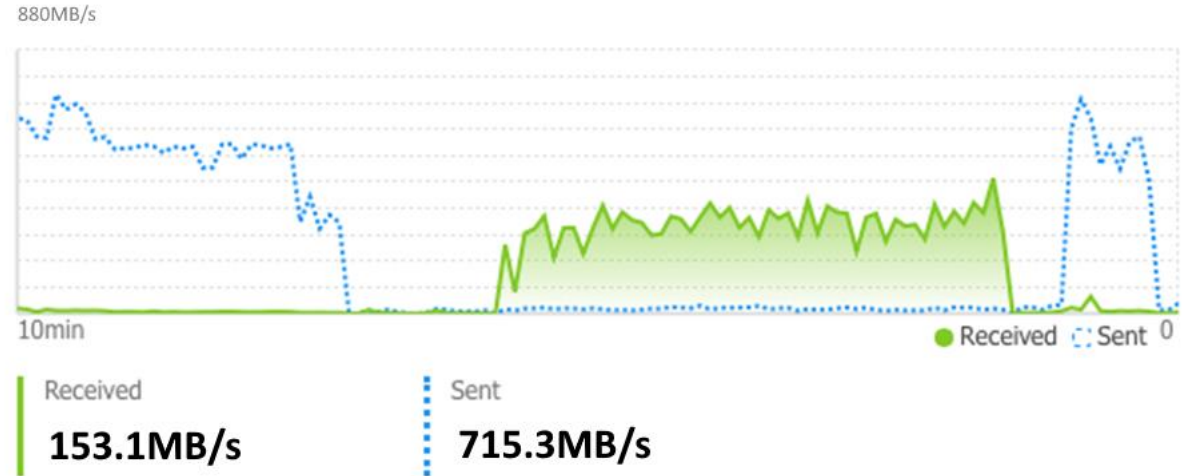
Beurteilen und behandeln
Sie diesen Incident



IR-Übungsfall - 5

Dem Netzwerk Administrator einer Unternehmung fällt auf, dass ein allgemein zugänglicher Client in der Entwicklungsabteilung ausserhalb der Bürozeiten grosse Datenmengen transferiert.

Beurteilen und behandeln
Sie diesen Incident



IR-Übungsfall - 6

Der Helpdesk wird überhäuft von Benutzeranfragen welche ihre Windows-PC nicht mehr verwenden können. Alle PCs zeigen unten stehendes Bild.
Die Firma verwendet SharePoint fürs Intranet, Exchange fürs Mail und Samba Server (Linux) für Fileshares.

Beurteilen und behandeln
Sie diesen Incident



IR-Datensammlung und Aufbewahrung

Incident Data Collection	Retention
Die gesammelten Daten nach dem Lessons-Learned-Meeting können verwendet werden um: - die Kosten des Vorfalls für die Budgetierung zu bestimmen - die Effektivität des CSIRT zu bestimmen - mögliche Sicherheitsschwachstellen im gesamten System zu identifizieren Die Zeit jedes Vorfalls gibt Aufschluss über den gesamten Arbeitsaufwand und die Gesamtzeit der einzelnen Phasen des IR-Prozesses. Man sammelt nur Daten, die zur Definition und Verfeinerung des IR-Prozesses verwendet werden können. Man sollte eine objektive Bewertung jedes Incidents durchführen.	Einige der entscheidenden Faktoren für die Aufbewahrung von Beweisen: Strafverfolgung - Wenn ein Angreifer wegen eines Sicherheitsvorfalls strafrechtlich verfolgt werden soll, sollten die Beweise aufbewahrt werden bis alle rechtlichen Schritte abgeschlossen sind. Datentyp - Eine Organisation kann festlegen, dass bestimmte Datentypen für einen bestimmten Zeitraum aufbewahrt werden sollen. Kosten - Wenn eine Menge Hardware und Speichermedien über einen langen Zeitraum aufbewahrt werden müssen kann das teuer werden.

IR Best Practice

- Obwohl die Reaktion auf Vorfälle (IR) heute ein wichtiger Prozess in Unternehmen ist, wird sie von vielen Firmen erst dann in Betracht gezogen, wenn ein Angriff stattgefunden hat.
- Daher ist die beste Chance, welche eine Organisation bei der Bewältigung eines Vorfalls hat, wenn der Reaktionsprozess gleich beim ersten Mal stimmt.
- Folgende best practice Ansätze unterstützen den IR-Prozess:
 - Erstellung eines einfach umzusetzenden IR-Plans
 - Aufbrechen von Informationssilos
 - Verwendung eines zentralisierten Ansatzes
 - Beurteilen und Überprüfen/Testen des IR-Plans
 - Grundlegende Aufgaben automatisieren
 - Vorlagen und Playbooks verwenden
 - Durchführen von Post-Incident-Reviews





IR-Plan

- Ein effektiver IR-Plan sollte folgende Punkte umfassen:
 - Definieren Sie wer für jede Phase des Prozesses verantwortlich ist
 - Definieren Sie wie jede IR-Phase durchgeführt werden soll
 - Geben Sie an (definieren Sie) welche geschäftskritischen Daten und Systeme und welche sensiblen Daten die höchste Priorität erfordern
 - Erklären Sie, wie und wo die Daten für die Forensik aufbewahrt werden sollen
 - Legen Sie die Kommunikationsprioritäten und Kommunikationsstelle fest
 - Legen Sie fest, wie und wann Sie die Strafverfolgungsbehörden einschalten



HelpDesk

Aufbrechen von Informations-Silos

- Organisationen verwenden heterogene Systeme, die am Ende Informationssilos bilden. Zum Beispiel könnten der Kunden-Helpdesk, der IT-Service-Desk und die Entwickler unterschiedliche Tools verwenden, welche in keiner Weise integriert und Daten austauschen.
- Daher kann sich ein Kunde über ein verdächtiges Problem mit einem Dienst beschweren, das in einem Helpdesk-Ticket "vergraben" wird. Das Ticket kann u.U. nicht korrekt gelöst oder rechtzeitig an die IT-Abteilung eskaliert werden. In den schlimmsten Fällen könnte das verdächtige Problem am Ende ein Angriff auf Kundenkonten oder das Unternehmen selbst sein.
- Die Verwendung von nicht verbundenen Systemen in Unternehmen führt oft zu Ineffizienzen im Informationsfluss, welche für die Cybersicherheit entscheidend sein können!

Verwendung eines zentralisierten Ansatzes

- Die Ansammlung von Sicherheitstools in vielen Unternehmen bedeutet heute, dass Sicherheitsteams oft auf mehrere Systeme und Plattformen zugreifen müssen um wichtige Details über einen Vorfall zu erhalten. Dies kann ressourcenintensiv und teilweise auch überfordernd zu sein, insbesondere während aktiver Sicherheitsvorfälle.
- Daher wäre es für Unternehmen idealer einen zentralisierten IR-Ansatz zu verwenden, bei dem die Tools so vorkonfiguriert sind, dass sie Daten an einen zentralen Ort zu senden.
- Wenn das IR-Team also auf ein Sicherheitsereignis reagieren muss, hat es alle notwendigen Datenpunkte an einem leicht zugänglichen Ort zur Verfügung.
- Weiterentwicklungen analysieren diese Daten bereits im Vorfeld (und stellen sie ggf. anderen Tools zur Verfügung) und beschleunigt so die Reaktion auf die Vorfälle
- Daher führt ein zentraler IR-Ansatz oft zu einer schnellen und effektiven Reaktion.

Grundlegende Aufgaben automatisieren (1)

- IR kann überfordernd sein, ins besonders in kleinen und mittelständischen Unternehmen, die möglicherweise nicht über die Ressourcen verfügen um adäquates Personal zu beschäftigen.
- Darüber hinaus ist es aufgrund der heutigen Organisationen, in denen Systeme von der lokalen IT-Umgebung bis hin zur Cloud reichen, für Sicherheitsteams fast unmöglich alle Benachrichtigungen über Sicherheitsereignisse zu bearbeiten.
- Wenn die Sicherheitsteams nicht überlastet sind haben sie aber bessere Chancen Vorfälle erfolgreich zu bearbeiten.
- Daher kann die Automatisierung einiger Aufgaben den Prozess vereinfachen und das Team entlasten. Zum Beispiel können sich wiederholende Prozesse wie der Zugriff auf Berichte aus verschiedenen Sicherheits-Tools automatisiert werden.

Grundlegende Aufgaben automatisieren (2)

- Antworten auf Tickets und Fallbacks sollten so automatisiert werden, dass nach einer bestimmten Zeit nach der ersten Meldung eines Vorfalls eine Garantie besteht, dass sich jemand um die Lösung des Problems kümmert.
- Ausserdem kann die Klassifizierung von Vorfällen bis zu einem gewissen Grad automatisiert werden indem diese mittels geeigneten Konfigurationen bereits zum Zeitpunkt der Datenerfassung automatisiert wird.
- Im Grossen und Ganzen profitiert die Organisation, aber insbesondere das Sicherheitsteam, von einem effektiven und automatisierten IR-Plan.
- Neben einer besseren Entscheidungsfindung und Schadensbegrenzung kann ein solcher Plan auch die SOC Betriebskosten senken, helfen bei der Teamkoordination und Verbesserung bei der Erkennung und Reaktion.

Beurteilen und Überprüfen – Testen des IR-Plans

Beim Testen des Plans sollten für folgende Punkte besonders beachtet werden:

- Die Fähigkeit jedes Teammitglieds, die skizzierten Verfahren zu befolgen
- Die im Plan auftretenden Engpässe
- Die Zeit welche benötigt wird, um einen Vorfall erfolgreich einzudämmen
- Die Ursachen für das Scheitern der Eindämmung eines Vorfalls, wenn diese nicht erfolgreich war



Vorlagen und Playbooks verwenden

- Es gibt IR-Vorlagen und Playbooks für verschiedene Arten von Sicherheitsereignissen die online von seriösen Quellen gefunden werden können.
- Zum Beispiel bietet die Website www.incidentresponse.com IR-Playbooks für Malware-Ausbrüche, Phishing, Datendiebstahl, unautorisierten Zugriff, Erhöhung der Berechtigung (z.B. Root-Zugriff) Events an.
- Jedes der Playbooks ist in die Phasen unterteilt, die ein IR-Team anwenden muss, um sich von einem bestimmten Sicherheitsvorfall vollständig zu erholen.
- Solche Playbooks sind hilfreich da sie Sicherheitsteams anleiten können, schnell auf einen Vorfall zu reagieren ohne bei Null anfangen zu müssen.
- Playbooks und Vorlagen sollten an die Bedürfnisse und Ressourcen einer Organisation angepasst werden.

Durchführen von Post-Incident-Reviews

Die Überprüfung nach einem Vorfall sollte drei Komponenten enthalten: **Vorbeugung, Verbesserung** und kein "finger pointing" bzw. **keine Schuldzuweisung**.

- Zur **Vorbeugung** gehört die Überprüfungen der Massnahmen welche zum Ende eines aktiven Vorfalls durchgeführt haben sowie deren Wirksamkeit.
Zum Beispiel: wenn Systeme durch das Team vom Netzwerk isoliert wurden konnte der Angriff gestoppt werden?
Gleiches gilt: wurde ein Phishing-Angriff gestoppt, wenn alle Kunden per E-Mail gewarnt wurden, nicht auf Links zu klicken?
- Die Betrachtung der Effektivität der Massnahmen zur Verhinderung des Vorfalles kann dem Team helfen, eine Strategie für den Umgang mit zukünftigen Vorfällen zu finden → **Verbesserung**
- Bei IR sollte nicht eine einzelne Person verantwortlich gemacht werden. Wenn z. B. ein System aufgrund eines falschen Software-Einsatzes durch einen IT-Mitarbeiter ausgefallen ist, sollte der Fokus auf den kausalen Faktoren liegen die dazu geführt haben. Indem man tiefer gräbt, könnten weitere Gründe für den Systemausfall zutage gefördert werden.

Literatur

Intelligence-Driven Incident Response; R. Brown, S. J. Roberts,
O'Reilly Media, Inc. ISBN: 9781491934944

<https://www.oreilly.com/library/view/intelligence-driven-incident-response/9781491935187/>

Crafting the InfoSec Playbook,
O'Reilly Media, Inc. ISBN: 9781491949405

<https://www.oreilly.com/library/view/crafting-the-infosec/9781491913598/>

Cybersecurity Incident Response, E.C. Thompson,
Apress, ISBN: 978-1-4842-3870-7

<https://www.apress.com/gp/book/9781484238691>

